

MNZHACK / SEGURIDAD INFORMÁTICA

Guía de cierre y sustentación

GUÍA INTERNA DE PREPARACIÓN

Dos vías de acceso documentadas. Una causa compartida de escalamiento. Evidencia, impacto y remediación con límites explícitos.

Juan David Ocampo Gonzalez | 38402

Jaime Andres Cardona Diaz | 40549

Daniel Quintero Hurtado | 31429

Eduardo Jose Villamil Arce | 37831

Periodo: 3-8 octubre 2026 / Corte: 7 octubre 2026

Versión 0.3 para revisión del equipo. No acredita pruebas adicionales ni aprobación cruzada.

Índice de preparación

Índice de preparación	2
01. Qué podemos afirmar hoy	3
02. Evaluación contra la rúbrica	4
03. Reparto para cerrar hoy	5
04. Cómo reconstruir la resolución propia	6
05. Comprobaciones útiles que faltan	8
06. Guion de exposición de 10 minutos	9
07. Preguntas de defensa y respuestas razonadas	10
08. Ensayo y control de entrega	11

01. Qué podemos afirmar hoy

La respuesta a la pregunta del parcial es sí: las capturas de Jaime y Daniel muestran acceso inicial y privilegio efectivo root en sus respectivas instancias. Jaime entró por la aplicación web; Daniel obtuvo acceso SSH con una credencial débil. Ambos escalaron aprovechando find con SUID. Son dos recorridos, con una causa de escalamiento compartida.

No podemos afirmar ocho vulnerabilidades únicas confirmadas, aislamiento verificado, limpieza realizada ni toda la cronología reconstruida. El resultado técnico puede estar demostrado mientras la ficha sigue en-validacion por falta de revisión de otro integrante.

La meta es defender cada afirmación con su figura. El PDF incorpora todas las evidencias registradas; no pedirle al profesor que abra un CherryTree o un enlace externo para ver la prueba.

02. Evaluación contra la rúbrica

Esta evaluación mide cobertura documental, no asigna la nota del docente. No se puede prometer 5.0 ni inferir una fórmula de conversión distinta de la publicada. La defensa vale 10 puntos que no puede suplir un PDF.

Criterio	Peso	Cobertura actual	Acción que mejora el cierre
Pre-Engagement	5	Parcial: alcance y reglas escritos	Adjuntar aislamiento, snapshot y justificar conocimiento previo
Reconocimiento / enumeración	10	Evidenciado: inventarios, HTTP y RPC	Explicar decisiones y separar IP/MAC de cada instancia
Threat Modeling	5	Desarrollado en sección 13	Cada integrante explica activos, fronteras y prioridades
Análisis de vulnerabilidades	15	Parcial: ocho fichas, límites explícitos	Cerrar CVSS, clasificación de observaciones y revisión cruzada
Explotación	20	Acceso web y SSH evidenciados	Completar versión del módulo y origen del candidato/hash
Post-explotación / escalamiento	10	EUID root evidenciado; cobertura parcial	Prueba conjunta de identidad y registro de limpieza
Informe profesional	25	Estructura, índice, fichas, diagramas y figuras integradas	Revisión humana completa de exactitud y legibilidad
Defensa	10	Guion y preguntas preparados	Ensayo aleatorio por los cuatro, sin memorizar solo su parte

Los 25 puntos del informe se distribuyen en resumen ejecutivo (3), alcance/metodología (2), presentación (3), fichas (5), evidencia (5), impacto (2), recomendaciones (3), cadena/conclusión (1) y referencias (1). Revisarlos como criterios separados, no sumar otra vez a los 100.

Prioridad: evidencia faltante de alcance y prueba final, fichas defendibles y ensayo. No cambiar honestidad por cantidad de vulnerabilidades. Una limitación bien explicada evita una afirmación falsa, aunque no garantiza el puntaje completo.

03. Reparto para cerrar hoy

Integrante	Entrega concreta	Lo revisa
Juan	Configuración UTM; comprobar referencias del PDF; explicar cadena Jaime	Jaime
Jaime	Cronología PT-001 a 004; origen hash/wordlist; versión del módulo; cambios y limpieza	Juan
Daniel	Evidencia final identidad/root; origen de flag4; impactos CVSS SSH; limpieza	Eduardo
Eduardo	Capturas de avances reportados o declaración de límite; explicar cadena Daniel	Daniel

Cada revisión debe registrar nombre, fecha real, figuras consultadas y decisión por ficha. No marcar confirmado automáticamente. Si hay desacuerdo, escribirlo y conservar en-validacion. Coordinar la edición: nadie debe escribir simultáneamente el mismo CTB/CTD.

Antes de entregar: confirmar nombre del equipo, institución/docente, hora y canal. La versión actual no inventa esos datos. Guardar el PDF exacto que se entrega y su SHA-256.

04. Cómo reconstruir la resolución propia

Este recorrido explica las pruebas propias disponibles. No procede de walkthroughs ni autoriza acciones fuera de DC-1. Antes de una nueva sesión, comprobar identidad, aislamiento y snapshot conforme al alcance del repositorio. Crear una especificación de prueba antes de ejecutarla.

Paso 1. Entender el laboratorio

Explicar qué máquina ataca, cuál es DC-1 y qué evidencia las identifica. Una IP privada no prueba aislamiento. Mostrar configuración Host-Only/Internal, interfaces y correlación MAC/IP de la VM. La red de Juan difiere de la de sus compañeros; no copiar sus direcciones en comandos.

Resultado de cierre: figura del hipervisor y ficha de instancia con propietario, IP/MAC, snapshot y fecha real. Si falta, declararlo. No realizar escaneos adicionales mientras la red siga sin verificarse.

Paso 2. Leer el reconocimiento

Usar EV-JDOG-002 o EV-JACD-015/016/017. Interpretar 22 como SSH, 80 como HTTP, 111 como rpcbind y el puerto alto como status RPC de esa instancia. Los puertos altos difieren por sesión/instancia. No inventar un puerto común.

En el comando de Juan, -p cubre los puertos TCP 1 a 65535, -sV sondea versiones y -sC ejecuta scripts predeterminados. No incluye -O ni un escaneo UDP. Nmap reporta servicios; no confirma vulnerabilidades. El registro UDP dentro de rpcinfo no equivale a escanear UDP.

Decisión: priorizar HTTP por aplicación y superficie observada; conservar SSH como vía de autenticación y RPC como superficie por caracterizar. TTL, banners y generador del CMS son indicios que necesitan contexto.

Paso 3. Explicar el acceso de Jaime

Abrir EV-JACD-014 (opciones), 003 (sesión) y 009 (identidad). El módulo observado es drupal_drupageddon y la asociación técnica es CVE-2014-3704, una SQL Injection. Una entrada controlada afecta consultas de la aplicación; el módulo utiliza ese fallo para conseguir ejecución. Explicar esta relación sin afirmar que la captura muestra cada consulta SQL o el código fuente exacto instalado.

RHOSTS designa el objetivo; TARGETURI la base web; LHOST/LPORT el destino al que regresa la conexión; el payload determina el código ejecutado. LHOST debe ser alcanzable desde el laboratorio. La sesión www-data tiene privilegios del proceso web, no root. La evidencia de sesión valida el resultado; configurar opciones por sí solo no lo hace.

Falta recuperar versión/hash del módulo usado y continuidad temporal. No confundir este recorrido con CVE-2018-7600: PT-005 sigue sin PoC propia.

Paso 4. Explicar el acceso de Daniel

EV-DQH-006 acredita autenticación password; 007 solo muestra una enumeración en progreso. Por tanto, no afirmar que ese módulo descubrió flag4. Preguntar al autor cómo obtuvo ese candidato y registrar la respuesta como reportada hasta tener evidencia.

EV-DQH-008 muestra Hydra con credencial obtenida; 009 demuestra login SSH; 010 muestra el entorno del usuario. -l fija un usuario, -P indica diccionario y -t controla concurrencia. La duración visible es 2 minutos 35 segundos. Haber encontrado una contraseña concreta no demuestra que todas las cuentas sean débiles.

No repetir fuerza bruta para ensayar la exposición: explicar las capturas y sus parámetros. Si se solicita una nueva validación, definir primero límites, identidad y condición de parada.

Paso 5. Explicar SUID y root

En EV-DQH-011/012 y EV-JACD-007/008/004, el problema es un ejecutable de propósito general con dueño root y bit SUID. find puede lanzar otro programa mediante -exec. En la secuencia observada, bash -p conserva el privilegio efectivo; sin esa conservación, el comportamiento de la shell puede ser diferente.

UID real identifica al usuario original; EUID es la identidad efectiva empleada para comprobaciones de privilegio. Daniel conserva UID 1001 y alcanza EUID 0; Jaime conserva UID 33 y alcanza EUID 0. No decir que ambos UID cambiaron a cero. El símbolo # o una bandera por sí solos no son prueba suficiente: id y hostname aportan evidencia más directa.

Jaime preparó /tmp/rootbash. La primera copia no cumplió su propósito porque conservaba dueño www-data; la corrección mediante find produjo un archivo de root. El fallo ayuda a explicar por qué importa el propietario junto con SUID. No ocultarlo ni presentar el archivo creado por el evaluador como configuración original.

Paso 6. Entender las ramas posteriores

PT-003: recuperar una contraseña con Hashcat y entrar como admin no prueba por sí solo un algoritmo débil. El diccionario incluía la respuesta; aclarar su procedencia y la extracción del hash. Separar acceso previo, material obtenido y cracking offline.

PT-004: el evaluador habilitó PHP Filter. Es ejecución de contenido bajo una configuración administrativa inducida, no una RCE anónima preexistente. Explicar qué cambió, qué rol pudo hacerlo y cómo revertirlo.

PT-006: un web.config accesible no equivale automáticamente a filtración sensible. Describir contenido e impacto demostrado; si no hay secretos ni efecto validado, tratarlo como observación. Dirty COW: descargar dirty.c no demuestra explotación ni ausencia de vulnerabilidad.

05. Comprobaciones útiles que faltan

Estos comandos son una propuesta de documentación para una sesión existente y autorizada sobre la instancia verificada; no se ejecutaron al elaborar esta guía. No dependen de repetir explotación.

Identidad en una misma sesión

```
date -Is
whoami
id
hostname
ip addr
pwd
uname -a
```

Capturar comando y salida juntos, con el identificador de instancia y la zona horaria registrada. Si una utilidad no está disponible, conservar el error y documentar alternativa. No editar el reloj retrospectivamente para hacerlo coincidir con una prueba pasada. La fecha nueva acredita una comprobación nueva, no la captura antigua.

Estado de permisos y cierre

```
ls -l /usr/bin/find
ls -l /tmp/rootbash
```

La segunda ruta es relevante para la instancia de Jaime, donde fue documentada. Una ausencia actual no prueba que nunca existió. Inventariar además archivos descargados, contenido PHP, formatos habilitados, listeners y sesiones. Acordar retirada de artefactos propios o restauración de snapshot; no borrar rutas a ciegas ni registrar limpieza sin evidencia posterior.

Para retest en una copia corregida: retirar el SUID innecesario con autorización de cambio, comprobar permisos y verificar desde usuario bajo que el mecanismo ya no obtiene EUID 0. Para SSH: comprobar acceso administrativo alternativo antes de restringir password y confirmar que el secreto comprometido deja de servir. Para Drupal: actualizar/migrar, comprobar funcionamiento y que el vector deja de abrir sesión. Registrar regresiones o fallos, no solo éxitos.

Registro mínimo de una nueva evidencia

ID nuevo, autor, instancia, fecha real con zona, pregunta, comando, salida, interpretación, límite, SHA-256 y ficha relacionada. Nunca sobrescribir el PNG antiguo. El resultado esperado se escribe antes; el observado se completa después. Una plantilla vacía no es prueba realizada.

06. Guion de exposición de 10 minutos

Tiempo orientativo	Quién inicia	Mensaje / figura
0:00-1:00	Juan	Pregunta, alcance, instancias y limitaciones de aislamiento
1:00-2:15	Eduardo	Nmap/HTTP, qué se observó y por qué priorizar web
2:15-4:15	Jaime	Módulo, parámetros y acceso www-data; figuras 003/014 de Jaime
4:15-5:45	Daniel	Password SSH, credencial y login; figuras 006/008/009 de Daniel
5:45-7:15	Daniel y Jaime	SUID, UID/EUID y causa compartida; figura 011 de Daniel
7:15-8:30	Eduardo	Impacto, remediaciones y retest propuesto
8:30-10:00	Juan	Conclusión, límites, qué falta y respuesta a la pregunta inicial

El tiempo es una propuesta de ensayo, no duración anunciada por el docente. Cada integrante debe poder reemplazar al otro. Mantener abierto el PDF con sus marcadores; buscar por EV para ir a la evidencia exacta. No improvisar una explotación en vivo sin que el docente la pida y el laboratorio esté preparado.

Frase de apertura sugerida: Evaluamos si un atacante en la misma red podía comprometer DC-1. Documentamos dos entradas distintas y una causa común de escalamiento. Mostraremos qué prueba cada captura, qué límites conserva y qué cambio corta la cadena.

07. Preguntas de defensa y respuestas razonadas

¿Cómo saben que era DC-1? Correlacionamos autor, IP/MAC, reconocimiento e identidad en la shell. El hostname se repite en copias y no basta solo. La configuración de VM todavía debe adjuntarse donde falta.

¿Por qué no cuentan ocho vulnerabilidades? Hay ocho fichas históricas; dos describen la misma causa SUID, una es hipótesis y otra exposición sin impacto. PHP Filter además depende de un cambio administrativo del evaluador.

¿Por qué una versión antigua no confirma una CVE? Puede haber backports, configuración distinta o detección imprecisa. Contrastamos fuente y comportamiento, luego observamos el efecto con precondiciones claras.

¿Cuál es la diferencia entre CVE, CWE y CVSS? CVE identifica una vulnerabilidad específica; CWE clasifica el tipo de debilidad; CVSS expresa severidad técnica bajo métricas declaradas. No son intercambiables ni una nota del parcial.

¿Por qué SUID es 7.8 y no 10? La propuesta requiere acceso local y privilegios bajos previos. No se puntúa como acceso remoto anónimo aunque sea un paso posterior de una cadena que comenzó por red. C/I/A altos describen impacto potencial de control administrativo.

¿Por qué el CVSS SSH sigue abierto? El vector recibido produce 9.1, pero asigna impactos altos que no se justifican solo por leer una bandera de flag4. Debemos delimitar recursos accesibles por esa cuenta; no sumar automáticamente root obtenido por otra falla.

¿Ya era root al entrar por Drupal? No. La primera sesión es www-data. Root efectivo aparece después por SUID. Son causas y pruebas diferentes.

¿La contraseña recuperada prueba un hash inseguro? No por sí sola. Importan entropía del secreto, costo del algoritmo y precondiciones para obtener el hash. La procedencia del diccionario debe poder explicarse.

¿El archivo web.config es crítico? No hay impacto validado que lo justifique. Su accesibilidad es observación, no evidencia automática de secreto expuesto.

¿Qué cambia al corregir find? Se corta el escalamiento observado, pero no se corrige la entrada web ni la contraseña SSH. La remediación debe cubrir cada causa, no solo el último paso.

¿Qué no probaron? No se acreditó toda la cobertura local ni un escaneo UDP independiente; no se probaron DoS ni pivoteo. La ausencia de prueba no se describe como ausencia de riesgo.

¿Por qué hay pendientes en un informe profesional? Porque se explicitan límites de verificación. La revisión documental no puede crear capturas, fechas o firmas que nunca se produjeron. El equipo debe cerrar los pendientes de mayor peso antes de entregar.

08. Ensayo y control de entrega

Primera ronda: cada uno explica una figura de otro en 90 segundos: pregunta, comando, resultado, límite y siguiente decisión. Segunda ronda: recorrer la cadena completa sin notas. Tercera ronda: responder dos preguntas anteriores y justificar una remediación con su retest. Registrar dudas; no aprobar por memoria de nombres de herramientas.

Revisar portada, 25 apartados, índice, referencias EV, interpretación de cada figura, conteo por causa, CVSS justificado, prueba final y configuración de laboratorio. Abrir el PDF en el equipo de la presentación y comprobar legibilidad de capturas ampliadas. La guía es interna: al docente se entrega únicamente el informe según el enunciado.

La revisión automática valida estructura y hashes, no la veracidad de una captura ni el dominio oral del equipo. Quien revise una ficha debe poder reconstruirla leyendo solo el informe. Si algo sigue sin evidencia, explicar el límite en lugar de inventar el resultado.

Fuentes: enunciado académico, páginas 3-9; evidencias propias citadas en el informe; FIRST CVSS 3.1 (<https://www.first.org/cvss/v3.1/specification-document>); código del módulo Rapid7 citado en la sección 24 del informe. No se consultaron soluciones específicas de DC-1.